Table 13.2 Trade-offs among C³ enforcement layers

Enforcement layer	Typical scope	Strengths	Trade-offs
Gateway PEP	Coarse-grained, global	Strong isolation; central visibility; early rejection of invalid requests	Limited contextual depth; dependent on token claims
Service PEPs	Fine-grained, per-action	Rich context; low latency; close to data and relationships	Requires deeper service integration and careful cache management
UI enforcement	Client-side experience	Improves responsiveness and prevents futile requests	Not security-critical, but must stay aligned with backend policies for a good user experience

Together, these layers form a defense-in-depth approach: the gateway enforces global boundaries, service PEPs enforce data-level rules, and the UI reflects those decisions to the user. The combination provides strong security, consistent behavior, and a smoother experience across every tenant in C³. The final part of C³'s design is the policy architecture itself: the framework that decides how policies are written, shared, and evaluated across tenants. Externalizing authorization pays off only when the policies behind it are clear, consistent, and safe to extend. For ACME, this meant defining not just where decisions happen but also which policies apply at each layer. policies apply at each layer.

13.5.6 Three layers of policy

C³ organizes authorization logic into three layers, as depicted in Figure 13.3.